

CodeNova

Security & Privacy Document

Document Version: 1.0 **Website:** CodeNova Business Website

Important: This document is a practical website security specification plus a privacy-policy template. It should be reviewed and adapted to CodeNova's actual business details, data practices, hosting providers, countries served, contracts and applicable laws before publication.

PART A — SECURITY REQUIREMENTS

1. Security Objectives

- Protect client, visitor, lead and administrator information from unauthorized access, disclosure, alteration and loss.
- Reduce risks from common web attacks and insecure integrations.
- Protect administrator accounts and internal business data.
- Keep secrets, API keys and database credentials out of client-side code.
- Maintain reliable backups, monitoring and an incident-response process.

2. Authentication & Authorization

- Public visitors should not need an account to browse the website or submit a basic inquiry.
- Administrative functions must require authentication.
- Use role-based authorization for administrator and staff accounts.
- Authorization must be verified server-side on every protected operation.
- Use secure sessions/tokens with appropriate expiration and refresh handling.
- Enable multi-factor authentication for administrator accounts where supported.
- Apply account logout, throttling or additional verification where appropriate for repeated failed authentication attempts.

3. Password Security

- Passwords must never be stored in plaintext.
- Use a modern password-hashing algorithm such as Argon2id or bcrypt with appropriate configuration.
- Never log passwords, password-reset tokens or authentication secrets.
- Password-reset links must be short-lived, single-use and invalidated after use.

4. API & Input Security

- Validate all input on the server, even if client-side validation exists.
- Sanitize data where appropriate and safely encode output.
- Use parameterized queries or a trusted ORM to reduce SQL injection risk.
- Apply rate limiting to contact forms, login endpoints and other abuse-prone APIs.
- Return generic error messages to users while keeping detailed errors in secure server logs.

- Limit API responses to only the data required by the requesting user.

5. Web Application Security

- Use HTTPS in production.
- Configure security headers appropriate to the application, including a suitable Content Security Policy where practical.
- Protect against cross-site scripting (XSS), SQL injection, CSRF where applicable, clickjacking and insecure direct object references.
- Use secure cookies with appropriate HttpOnly, Secure and SameSite settings where cookies are used.
- Restrict allowed CORS origins rather than using unrestricted wildcard access for private APIs.

6. Secrets & Environment Variables

- Keep database passwords, API keys, service-role keys, email-provider keys and OAuth secrets in secure server-side environment variables or a secrets manager.
- Never commit production secrets to Git.
- Never expose service-role database keys in browser bundles.
- Rotate credentials when exposure is suspected or when operationally appropriate.
- Use separate credentials for development, staging and production.

7. Database Security

- Use least-privilege database access.
- Protect administrative tables from public access.
- Use row-level security where supported and appropriate.
- Encrypt data in transit.
- Use provider-supported encryption at rest where available.
- Create regular backups and periodically test restoration.
- Retain only the data required for legitimate business purposes.

8. Lead & Contact Data Protection

- Collect only information necessary to respond to project inquiries.
- Restrict lead records to authorized CodeNova personnel.
- Do not expose lead lists through public APIs.
- Record administrative access or important changes where practical.
- Define retention periods and securely delete information that is no longer needed, subject to legal/business requirements.

9. File & Media Security

- Validate uploaded file type, size and extension if uploads are enabled.
- Store uploads outside directly executable server locations where possible.
- Use randomized file names and access controls.

- Scan uploaded files for malware when the risk and use case justify it.
- Do not allow arbitrary executable files to be uploaded.

10. Third-Party Integrations

- Use reputable providers for hosting, database, email, analytics, payments and scheduling.
- Share only the minimum data required with each provider.
- Keep provider credentials server-side.
- Review third-party privacy and security documentation before integration.
- Maintain a current inventory of external services and the data each service receives.

11. Analytics & Tracking Security

- Do not send unnecessary personally identifiable information to analytics platforms.
- Use consent controls where required for non-essential cookies or tracking.
- Limit analytics access to authorized users.
- Document the purpose of tracking technologies.

12. Security Monitoring

- Monitor application errors, authentication anomalies and unusual traffic.
- Maintain secure logs without storing passwords, authentication secrets or unnecessary sensitive data.
- Alert administrators to significant security events.
- Review dependencies and security advisories regularly.

13. Incident Response

- Maintain a documented process for detecting, containing, investigating and recovering from security incidents.
- Immediately rotate affected credentials when compromise is suspected.
- Preserve relevant logs and evidence where appropriate.
- Assess affected systems and data.
- Communicate with affected parties and authorities when required by applicable law or contractual obligations.
- Document the incident, root cause and corrective actions.

14. Secure Development Lifecycle

- Use Git with protected production branches where practical.
- Require code review for security-sensitive changes.
- Run linting, type checks, dependency checks and automated tests before production deployment.
- Keep dependencies updated and remove unused packages.
- Review authentication, authorization and data-access changes carefully.
- Use separate development and production environments.

15. Security Checklist Before Launch

- HTTPS enabled.
- Admin authentication enabled.
- Admin authorization tested.
- Database access policies tested.
- Production secrets removed from source code.
- Public APIs rate-limited.
- Forms protected against spam/abuse.
- Backups configured.
- Error handling does not reveal secrets.
- Security headers reviewed.
- Analytics privacy settings reviewed.
- Incident-response contacts documented.

PART B — PRIVACY POLICY

The following is a publication-ready starting template. Replace all bracketed business details and adjust it to CodeNova's actual data collection, vendors, jurisdictions and legal obligations before publishing.

Privacy Policy Template — CodeNova

- This Privacy Policy explains how CodeNova may collect, use, store and protect information when visitors use the CodeNova website and related services.
- **Effective Date:** [Insert Date]
- **Last Updated:** [Insert Date]
- **Legal Business Name:** [Insert Legal Name]
- **Contact Email:** [Insert Privacy Email]
- **Business Address:** [Insert Business Address]

1. Information We Collect

- **Information you provide:** name, email address, phone number, company/business name, country, project requirements, budget information, consultation details and messages submitted through forms.
- **Automatically collected information:** IP address, browser type, device type, operating system, pages viewed, referring source, approximate usage information and technical logs, subject to the configuration of the website and applicable law.
- **Information from third-party services:** if you choose an integrated service such as a calendar or communication provider, we may receive information necessary to provide that requested service.

2. How We Use Information

- Respond to project inquiries and consultation requests.
- Prepare estimates, proposals and project discussions.
- Provide requested services and communications.
- Improve website functionality, content and user experience.
- Measure website traffic and marketing performance where permitted.
- Prevent fraud, spam, abuse and security incidents.
- Maintain business records and comply with applicable legal obligations.

3. Legal Basis / Permission

- Where applicable, CodeNova processes personal information based on consent, contractual necessity, legitimate business purposes, legal obligations or other lawful grounds recognized by applicable privacy law.
- Where consent is required, users may withdraw consent through the available mechanism, subject to applicable limitations.

4. Cookies & Similar Technologies

- CodeNova may use essential cookies or similar technologies needed for website functionality.
- Analytics or marketing technologies may be used only as configured and where legally permitted or consented to when required.

- Users can manage cookies through browser settings and any consent-management tools provided on the website.

5. How We Share Information

- CodeNova does not sell personal information as a general business practice.
- Information may be shared with service providers that help operate the website or business, such as hosting, database, email, analytics, scheduling, security and communication providers.
- Information may also be disclosed where required by law, to protect rights and safety, or as part of a business transaction such as a merger, acquisition or restructuring, subject to applicable requirements.

6. Data Retention

- CodeNova retains personal information only for as long as reasonably necessary for the purpose for which it was collected, legitimate business needs, contractual requirements or applicable legal obligations.
- Retention periods may vary by information type. CodeNova should maintain an internal retention schedule for leads, inquiries, analytics data, invoices and account records.

7. Data Security

- CodeNova uses reasonable technical and organizational safeguards designed to protect personal information against unauthorized access, loss, misuse, alteration or disclosure.
- No internet transmission or storage system can be guaranteed to be completely secure.

8. Your Privacy Rights

- Depending on the user's location and applicable law, users may have rights concerning access, correction, deletion, restriction, objection, portability, withdrawal of consent or other rights.
- To make a privacy request, contact CodeNova using the privacy contact information published on the website.
- CodeNova may need to verify the identity of the requester before fulfilling a request.

9. International Data Transfers

- Because CodeNova may use cloud and technology providers operating in different countries, personal information may be processed outside the user's country.
- Where required, CodeNova should use appropriate safeguards and contractual or legal mechanisms for international transfers.

10. Children's Privacy

- The website is intended for business and general audiences and is not designed to knowingly collect personal information from children where prohibited by applicable law.
- If CodeNova becomes aware that prohibited child data has been collected, it should take appropriate steps to address the situation.

11. Third-Party Links

- The website may contain links to third-party websites or services. CodeNova is not responsible for the privacy practices of third-party sites and users should review their respective privacy notices.

12. Business Communications

- If a visitor submits an inquiry, CodeNova may contact them by email, phone or another provided method regarding the inquiry, proposal or requested service.
- Marketing communications should be sent only where legally permitted and should include an appropriate unsubscribe or preference mechanism where required.

13. Changes to This Policy

- CodeNova may update this Privacy Policy when business practices, technology or legal requirements change.
- The updated version should be published on this page with a revised effective or last-updated date.

14. Contact

- For privacy questions or requests, contact:
- **CodeNova Privacy Contact:** [Insert Name/Team]
- **Email:** [Insert Email]
- **Phone:** [Insert Phone]
- **Address:** [Insert Business Address]

Implementation Note

The Security section should be used by the development team as a technical baseline. The Privacy Policy should be kept synchronized with the actual production website: forms, cookies, analytics, hosting, CRM, email provider, scheduling tools, payment providers and any AI services should all be reflected accurately.

This document is not a substitute for advice from a qualified privacy or legal professional. Before public launch, CodeNova should review the final policy for the jurisdictions in which it operates and serves customers.